AI Audit Checklist & Certification Playbook

Practical field guide for auditing organizational use of artificial intelligence, assessing control maturity, and preparing for AI-management certification.

Primary certification route	ISO/IEC 42001 AI management systems
Supporting audit lenses	NIST AI RMF, ISO/IEC 23894, ISO/IEC 42005, NIST GenAI Profile, EU AI Act basics

Prepared for study and implementation planning

1. Purpose and intended use

This playbook turns the major AI governance and assurance documents into a working audit packet. It is designed for internal auditors, security and risk teams, compliance leads, consultants, and prospective certifying assessors who need a repeatable way to evaluate how an organization develops, procures, deploys, and uses AI systems.

The playbook is written around the clearest available certification route for an organization: building and assessing an Artificial Intelligence Management System (AIMS) aligned to ISO/IEC 42001. The control logic and evidence questions are then strengthened with NIST AI RMF 1.0, ISO/IEC 23894 risk guidance, ISO/IEC 42005 impact assessment guidance, the NIST Generative AI Profile, and basic EU AI Act obligations for organizations with European exposure.

2. Standards and framework stack

Source	Main purpose	Use in audit	Certification value
NIST AI RMF 1.0	Voluntary framework for trustworthy AI risk management	Structure governance, context, measurement, and management testing	Not a certifiable standard by itself
ISO/IEC 42001	Requirements for an AI management system	Primary organizational audit criteria	Main certifiable route
ISO/IEC 23894	Guidance on AI risk management	Deepen risk analysis and treatment testing	Support standard
ISO/IEC 42005	Guidance on AI system impact assessment	Assess use-case specific human, societal, and business impact analysis	Support standard
NIST GenAI Profile	Companion profile for generative AI risk	Strengthen LLM/chatbot/copilot control testing	Support profile
EU AI Act basics	Legal obligations under EU law	Check legal scope, classification, transparency, and provider/deployer duties	Compliance overlay, not ISO certification

3. Audit outputs

- Executive report with overall rating, key risks, and certification readiness view.
- Detailed findings register with criterion, evidence, gap, severity, and remediation owner.
- AI system inventory and in-scope use-case register.
- Maturity scorecard by control domain.
- Nonconformity log for ISO/IEC 42001 readiness or certification activity.
- 30 / 60 / 90 day remediation plan and management action tracker.

4. Audit methodology

1. Define scope. Confirm which entities, business units, products, vendors, and AI use cases are in scope.
2. Build the AI inventory. Identify internal AI, embedded AI, third-party AI, and shadow or unapproved use.
3. Classify use cases. Separate low-risk productivity uses from high-impact systems affecting customers, workers, safety, credit, healthcare, security, or regulated decisions.
4. Map obligations and controls. Align each in-scope system to governance, risk, legal, security, data, oversight, transparency, and monitoring requirements.
5. Test design and operating effectiveness. Review documents, interview stakeholders, inspect configurations, and sample live systems or workflows.
6. Score maturity and severity. Rate each domain for policy design, implementation, evidence quality, monitoring, and corrective action capability.
7. Issue findings and readiness opinion. Distinguish conforming controls, partial controls, absent controls, and critical blockers to certification.

5. Scoring model

Use one maturity score and one assurance score. Maturity evaluates how established the control system is. Assurance evaluates whether there is enough tested evidence to trust that the control works in practice.

Score	Maturity label	Meaning
0	Absent	No defined control, no owner, or no evidence.
1	Ad hoc	Control exists informally, inconsistently, or only in pockets.
2	Repeatable	Documented control exists and is usually followed, but not fully governed.
3	Managed	Defined owner, evidence, review cadence, and remediation workflow are in place.
4	Measured	Control effectiveness is monitored with metrics, logs, or QA activity.
5	Optimized	Control is integrated into enterprise governance with continuous improvement.

6. Severity model for findings

Use severity to prioritize remediation and certification decisions.

Severity	Typical trigger	Certification impact
Critical	No AI governance owner, no inventory, unsafe or unlawful use, no incident response, or major unmitigated high-risk deployment	Blocks certification or triggers immediate escalation
High	Key control designed but not operating, major legal or security gap, missing impact/risk review for important use case	Likely major nonconformity
Medium	Partial implementation, weak evidence, inconsistent review, or gaps in training and monitoring	Minor nonconformity or corrective action required
Low	Optimization issue, documentation weakness, or isolated process drift	Does not block readiness if tracked and scheduled

7. Pre-audit evidence request list

Request these artifacts before fieldwork. Missing baseline documents is itself a finding.

Governance and management system

- AI policy, AI acceptable-use policy, AI development standard, and AI procurement standard
- AI governance charter or steering committee terms of reference
- Organization chart showing accountable executives, risk owners, legal, privacy, security, and technical owners
- Management review minutes, internal audit plans, and corrective action tracker

Use-case and inventory records

- Complete AI use-case register including internally built, embedded, and vendor-provided AI
- System purpose, owner, user group, deployment environment, and criticality
- Register of generative AI tools, copilots, chatbots, and model APIs

Risk, impact, and compliance artifacts

- AI risk assessments, model risk assessments, and impact assessments
- Legal/compliance review memos, DPIAs if applicable, and EU AI Act classification notes
- Human oversight design or approval matrices for important decisions

Security and operations

- Access-control matrix, role design, logging standards, prompt or model change control, secure SDLC documents
- Incident response playbooks for AI misuse, data leakage, harmful outputs, or vendor outages
- Monitoring dashboards, evaluation reports, red-team results, and rollback or kill-switch procedures

Third-party and data governance

- Vendor due-diligence checklist, contracts, DPAs, model documentation, and subprocessor lists
- Data lineage, retention, training/fine-tuning data approvals, and sensitive-data restrictions

8. Detailed AI audit checklist

Use the following domains as the core of the audit. Each domain includes objective, what to test, sample evidence, and red flags. A practical engagement usually samples every domain and performs deeper testing on the highest-risk use cases.

A. Governance and accountability

Objective: Verify that AI is governed as a managed program with executive sponsorship, clear ownership, approved policies, and regular oversight.

What to test

- Named accountable executive and management representative

- AI governance committee with defined cadence and quorum
- Documented scope of AI policy including procurement and use of third-party tools
- Defined approval path for new AI use cases and material changes
- Internal audit, corrective action, and management review process

Sample evidence

- Governance charter, policy set, committee minutes, organization chart, internal audit logs

Red flags

- No single accountable owner
- Business units use AI independently with no central rules
- Policy exists but has no evidence of enforcement

B. AI inventory and use-case classification

Objective: Verify the organization knows where AI is used and can distinguish low-risk from high-impact or regulated deployments.

What to test

- Central inventory includes internal, embedded, vendor, and experimental systems
- Each entry has owner, purpose, data type, user population, deployment status, and criticality
- Use cases are classified by risk, impact, and applicable regulation
- Shadow AI or unapproved tools are monitored and addressed

Sample evidence

- Inventory export, CMDB linkage, SaaS app inventory, procurement records, discovery logs

Red flags

- No complete inventory
- Chatbots or copilots deployed without review
- AI used in HR, customer, or security decisions without classification

C. Risk management and impact assessment

Objective: Verify AI-specific risk and impact analysis is performed before deployment and refreshed after material change.

What to test

- Use-case risk assessment completed before launch
- Impact assessment considers affected individuals, groups, society, and business process harm
- Residual risk acceptance is documented
- Risk treatment actions are assigned, tracked, and retested

Sample evidence

- Risk register, impact assessment templates, approval forms, treatment plans

Red flags

- Teams assess accuracy only and skip harm analysis
- No refresh after major model or prompt changes
- Risk treatment has no owner

D. Data governance and privacy

Objective: Verify data used by AI systems is lawful, appropriate, quality-controlled, and governed across collection, training, inference, and retention.

What to test

- Approved data sources and usage rights are documented
- Sensitive-data restrictions exist for public or shared models
- Retention and deletion rules cover prompts, outputs, logs, training sets, and fine-tuning data
- Data quality and lineage controls exist for important systems

Sample evidence

- Data maps, retention schedules, privacy reviews, DLP rules, training-data approvals

Red flags

- Employees paste sensitive data into external tools
- Training data provenance cannot be explained
- No control over retention of prompts or outputs

E. Security, resilience, and misuse resistance

Objective: Verify AI systems are secured against unauthorized access, harmful prompt behavior, data leakage, model abuse, and unsafe integration paths.

What to test

- Role-based access control and secrets management are implemented
- Model, prompt, agent, and plugin changes follow change control
- Guardrails, content filters, or policy controls exist where needed
- Logging supports abuse investigation and rollback
- Fallback or shutdown path exists for critical systems

Sample evidence

- IAM records, config exports, change tickets, evaluation logs, red-team reports, incident records

Red flags

- Shared admin credentials

- No logging for prompts or tool calls
- Production agents can take actions without sufficient approval or isolation

F. Human oversight and decision controls

Objective: Verify humans remain appropriately accountable for important decisions and that full automation is not used where it would create unacceptable risk.

What to test

- Decision rights specify when human review is required
- Escalation path exists for exceptions, overrides, and contested outputs
- Users are trained not to treat model output as unquestionable fact
- Systems affecting rights, employment, safety, credit, healthcare, or security have explicit oversight design

Sample evidence

- RACI matrices, SOPs, approval rules, training content, case review records

Red flags

- Material decisions are fully automated without review
- Human reviewer exists on paper but cannot realistically challenge output

G. Transparency, documentation, and user communication

Objective: Verify internal and external stakeholders get accurate information about how AI is used, what it can and cannot do, and how to report issues.

What to test

- System documentation includes purpose, limits, assumptions, and known failure modes
- Users are informed when they are interacting with AI where applicable
- Documentation supports auditability and legal review
- Model, prompt, or version history is traceable

Sample evidence

- System cards, user notices, release notes, transparency statements, version logs

Red flags

- No documented limits
- Marketing claims exceed tested capability
- Users cannot tell when AI is involved

H. Monitoring, evaluation, and incident response

Objective: Verify the organization monitors performance and harm over time and can respond quickly to misuse, drift, legal events, or harmful outputs.

What to test

- Pre-deployment testing criteria are defined and retained
- Ongoing monitoring covers quality, safety, fairness, abuse, and drift as relevant
- AI incident response playbook exists with named contacts and communication paths
- Serious issues trigger rollback, disablement, or emergency review

Sample evidence

- Dashboards, test suites, evaluation reports, incident tickets, rollback logs

Red flags

- No post-launch monitoring
- No criteria for harmful output escalation
- Incidents handled informally with no lessons learned

I. Third-party AI and vendor assurance

Objective: Verify external AI providers are reviewed, contracted, monitored, and governed with the same seriousness as internal systems.

What to test

- Vendor due diligence covers security, privacy, transparency, support, and subcontractors
- Contracts address data use, retention, model improvement, logging, and incident notice
- Material vendor changes trigger reassessment
- High-risk or mission-critical vendors have contingency plans

Sample evidence

- Due diligence questionnaires, contracts, DPAs, SOC/ISO reports, change notifications

Red flags

- Vendor selected by a single team with no risk review
- Contract silent on customer data use for model training

J. Training, awareness, and culture

Objective: Verify the workforce understands what AI tools are allowed, what data cannot be used, when to escalate, and how to challenge unsafe output.

What to test

- Role-based training exists for end users, builders, approvers, legal, and security teams

- Policy acknowledgements are tracked
- Guidance exists for secure prompting and prohibited use cases
- Leadership reinforces AI risk and accountability expectations

Sample evidence

- Training decks, completion reports, intranet guidance, awareness campaigns

Red flags

- No training for general users
- Developers and business owners interpret policy differently
- No channel to report unsafe AI use

9. Generative AI deep-dive checklist

Apply this section to LLM-based assistants, chatbots, agentic workflows, retrieval-augmented generation, code copilots, content-generation pipelines, and third-party foundation-model integrations.

Control area	Tests	Primary evidence	Risk if absent
Prompt and system-instruction governance	Version control, approval, and rollback for critical prompts or orchestrations	Prompt library, change tickets	Unsafe or inconsistent behavior
Grounding and retrieval controls	Trusted sources, retrieval scoping, and citation behavior where required	RAG config, corpus controls, eval reports	Hallucination, leakage, bad advice
Tool / plugin / agent permissions	Least privilege for actions, approvals for destructive steps, sandboxing	Agent policy, API scopes, test results	Unauthorized actions or fraud
Input and output protection	Prompt injection resistance, content filtering, sensitive-data protection	Adversarial tests, filters, DLP, evals	Leakage, jailbreak, abuse
Model and vendor transparency	Know model family, provider terms, retention, and regional/legal implications	Vendor docs, contracts, model cards	Hidden data use or unsupported reliance
Human review design	Escalation and override for high-impact use	SOPs, QA workflow	Over-automation

10. Certification playbook for ISO/IEC 42001 readiness

The organization should treat certification as a management-system program rather than a one-time paperwork event. A practical readiness sequence is shown below.

8. **Step 1 - Decide the scope:** Define the legal entity, sites, business units, and AI systems included in the AIMS. Avoid vague scope statements.
9. **Step 2 - Establish the AIMS:** Issue governance policy, assign owners, define objectives, identify interested parties, and document core processes.
10. **Step 3 - Build the control baseline:** Implement inventory, risk assessment, impact assessment, data governance, security, oversight, incident, and supplier controls.
11. **Step 4 - Operate and collect evidence:** Run the program long enough to generate evidence: approvals, reviews, logs, management minutes, findings, and corrections.

12. **Step 5 - Perform internal audit:** Test conformance to the management system requirements and verify control operation in selected use cases.
13. **Step 6 - Hold management review:** Leadership reviews status, risk, incidents, objectives, resource needs, and corrective actions.
14. **Step 7 - Correct nonconformities:** Close gaps before external certification activity.
15. **Step 8 - Stage 1 external audit:** Certification body reviews documentation and readiness.
16. **Step 9 - Stage 2 external audit:** Certification body tests implementation and operating effectiveness.
17. **Step 10 - Surveillance and recertification:** Maintain the system, respond to findings, and keep evidence fresh.

11. What should block certification

- No defined AIMS scope or no accountable management representative.
- No usable AI inventory or inability to identify in-scope systems.
- No risk / impact review process for material AI use cases.
- No training or no evidence users know the rules.
- No incident response path for harmful output, leakage, or unsafe automation.
- Critical legal or privacy exposure with no treatment plan.
- Major discrepancy between written policy and live operational practice.

12. Interview guide

Interviewee	Sample questions	Good signal
Executive sponsor	What AI decisions require your signoff? How do you review AI risk?	Can explain governance, scope, and unresolved risks.
Program owner	How are new AI uses approved and tracked?	Knows inventory, workflow, exceptions, and metrics.
Security lead	How are LLM apps, model APIs, and agent tools secured?	Can show specific controls and logs.
Privacy / legal	How do you classify uses with legal exposure?	Can show review criteria and issue handling.
Product / business owner	What human oversight exists and what are failure modes?	Understands purpose, limits, and escalation.
Operations / support	How are incidents reported and managed?	Can show runbooks, contacts, and recent examples.

13. Findings register template

ID	Criterion	Finding	Severity	Owner	Target date
F-01	Inventory	Generative AI tools are used in two business units without	High	CIO / AI program lead	30 days

		inclusion in the central AI register.			
F-02	Vendor assurance	Contract with chatbot provider does not clearly restrict customer-data use for model improvement.	High	Procurement / Legal	45 days
F-03	Monitoring	No formal post-launch quality and harm review exists for internal HR assistant.	Critical	HR system owner	15 days

14. 30 / 60 / 90 day remediation plan

Window	Primary goal	Typical actions	Output
0-30 days	Stabilize governance	Name owner, freeze unsafe uses, build inventory, issue interim policy, start incident path	Foundational control baseline
31-60 days	Close material gaps	Run risk and impact reviews, fix vendor/data gaps, define oversight rules, implement logging and training	Reduced exposure and better evidence
61-90 days	Prepare for readiness review	Internal audit, management review, corrective actions, finalize metrics and records	Certification readiness packet

15. Quick-use field checklist

Control checkpoint	Status	Evidence ref
Scope defined and approved	☐ Yes ☐ No ☐ Partial	
AI inventory complete enough to support sampling	☐ Yes ☐ No ☐ Partial	
High-impact systems identified	☐ Yes ☐ No ☐ Partial	
Policies published and	☐ Yes ☐ No ☐ Partial	

acknowledged		
Risk and impact assessments performed	☐ Yes ☐ No ☐ Partial	
Human oversight defined for important decisions	☐ Yes ☐ No ☐ Partial	
Data-use restrictions and retention rules in place	☐ Yes ☐ No ☐ Partial	
Security controls tested for AI-specific misuse	☐ Yes ☐ No ☐ Partial	
Monitoring and incident handling operating	☐ Yes ☐ No ☐ Partial	
Vendor controls documented	☐ Yes ☐ No ☐ Partial	
Training completed	☐ Yes ☐ No ☐ Partial	
Management review held	☐ Yes ☐ No ☐ Partial	

16. References used for this playbook

- NIST AI Risk Management Framework (AI RMF 1.0).
- NIST AI RMF Generative AI Profile (NIST AI 600-1).
- ISO/IEC 42001 AI management systems.
- ISO/IEC 23894 AI guidance on risk management.
- ISO/IEC 42005 AI system impact assessment.
- European Commission AI Act overview, timelines, and GPAI guidance.

Note: ISO publishes public abstracts and explainer pages for several standards; full clause text is generally licensed. This playbook therefore uses official public ISO descriptions for framing, plus the public NIST and European Commission materials.